

Practitioner Craft — Building a Compliance Program

Part 14 — AI Compliance · 14-ai-compliance/notes/03-building-a-compliance-program.md

Everything so far has been "what the rules say." This file is "what you actually do about it" — as the engineer or technical lead in the room, not as the lawyer.

1. Gap assessment: the only sane starting point

Do not start a compliance program by reading regulations cover to cover. Start by inventorying **what you actually have**, then map each item against **what applies to it**. A gap assessment is a table, not a document:

Use case	Jurisdiction(s)	Sector rules	AI-specific tier/rule	Data protection posture	Owner	Status
Resume screener	EU, US (NY)	Employment (Title VII, NYC LL144)	EU AI Act: high-risk (Annex III)	Candidate PII, no special-category data expected	ML lead	Gap: no bias audit yet
Support chatbot	Global	None sector-specific	EU AI Act: limited-risk (Art. 50 disclosure)	May surface account PII in responses	Product	Gap: no AI-disclosure banner
Internal analytics copilot	Internal only	None	EU AI Act: minimal-risk	Internal data, access-controlled	Data eng	No gap identified
Credit-decision assist	US	ECOA/Reg B, SR 26-2	Not EU-facing (n/a)	Applicant financial data	Risk	Gap: adverse-action reason codes not yet human-readable

The columns that matter: **jurisdiction** (compliance obligations are almost always jurisdiction-scoped — "is this EU-facing" changes everything), **sector** (does an existing regulator already own this domain), **tier/specific-rule** (from notes/01–02), **data-protection posture** (what personal/sensitive data flows through it), and **status** (a gap, not a checkbox). Do this exercise for every AI use case you can name, not just the ones that feel risky — the "internal analytics tool everyone forgot was AI" is a more common finding than the deliberately built high-risk system, precisely because nobody thought to classify it.

Re-run this table on a cadence (quarterly is reasonable for most orgs) because both columns move: you ship new use cases, and the applicable-rules column changes underneath you (see the Colorado and EU-timeline examples in notes/01).

2. One set of artifacts, multiple audiences — don't build parallel paperwork

The single most expensive compliance mistake is building a separate documentation trail *for compliance* on top of the documentation you already produce *for engineering*. The fix is recognizing that good engineering artifacts already answer most regulatory questions, if you write them with the second audience in mind from the start:

- A **model card** (Module 12 [12-ai-governance]) that documents training data, intended use, limitations, and evaluation results is most of an EU AI Act Annex IV technical-documentation entry, most of an ISO 42001 Annex A impact-assessment record, and a natural artifact for a SOC 2 auditor asking "how do you document AI system behavior."
- An **eval report** (Module 15 [15-ai-evals]) showing accuracy, robustness, and bias-slice breakdowns is the direct evidence for the Act's "appropriate levels of accuracy and robustness" requirement, for NYC LL144's bias-audit requirement, and for ISO 42001's performance-evaluation clause (Clause 9).
- A **trace/audit log** (Module 13 [13-ai-security]) capturing what a system did, on what input, with what output, satisfies the Act's record-keeping obligation, SOC 2's logging expectations, and — if a human reviewed or overrode a decision — your human-oversight evidence for both the Act and GDPR Article 22.
- A **risk register entry** (Module 12 [12-ai-governance]) is your risk-management-system evidence for the Act, and your Annex A risk-treatment evidence for ISO 42001.

The instructive exercise — automated by `code/compliance_documentation_mapper.py` [14-ai-compliance/code/compliance_documentation_mapper.py] in this module — is printing that mapping explicitly: which single artifact, already produced as normal engineering discipline, covers which requirement across which framework. When a compliance program shows up asking for a *new* document that isn't traceable to something an engineer would produce anyway, that's a sign the ask is either redundant or points at a real gap in your engineering practice, not a paperwork gap.

3. Working with legal counsel effectively

You are not there to give legal advice, and counsel is not there to review your code. The productive split:

What you bring to that conversation: - A precise, honest description of what the system does, on what data, with what human involvement at what point — not a marketing description. - The gap-assessment table above, pre-filled with your best technical read of jurisdiction/sector/tier, framed as "confirm or correct this," not "tell me what applies" from a blank page. - The artifacts (model card, eval report, logs) already assembled, so counsel is reviewing evidence, not requesting a document that then triggers a multi-week engineering side-quest. - Specific, falsifiable questions: "does this count as Annex III employment under Article 6(3)'s narrow-task exception, given it only re-ranks a shortlist a recruiter already assembled?" beats "is this compliant?" - Flags on anything genuinely novel or judgment-dependent — new modality, new jurisdiction, a use case that doesn't map cleanly onto an existing category.

What you should expect back, and shouldn't try to self-serve: a jurisdiction-specific legal classification, a read on genuinely ambiguous statutory language, a decision on litigation/regulatory risk tolerance, and sign-off on anything with contractual or liability exposure (vendor terms, license interpretation, user-facing disclosures).

The failure mode in both directions: engineers who treat "counsel hasn't objected" as compliance sign-off without ever asking the specific question, and counsel who get a vague system description and produce generic boilerplate that doesn't actually cover the system's real behavior. Precision on your side buys precision on theirs.

4. How to stay current

This module's content will be stale within months on several fronts. Bookmark and periodically check the **primary sources**, not blog summaries of them — summaries lag and compound errors:

Topic	Check here, directly	Why this one
EU AI Act text and timeline	artificialintelligenceact.eu and the EU AI Act Service Desk	Maintained implementation-timeline page and official Q&A, updated as amendments land
EU AI Act official legal text	EUR-Lex, Regulation (EU) 2024/1689	The actual binding text — cite this, not a summary, for anything load-bearing
GPAI Code of Practice	digital-strategy.ec.europa.eu	The Commission's own page, updated as the Code evolves
NIST AI RMF and profiles	nist.gov/itl/ai-risk-management-framework	New sector/use-case profiles are released on top of the core framework regularly
FTC AI enforcement	ftc.gov/industry/technology/artificial-intelligence	Enforcement actions and policy statements posted directly, ahead of law-firm commentary
US state AI legislation	A state-legislation tracker such as the IAPP US State AI Legislation Tracker or your jurisdiction's own legislature site	State activity is the highest-churn part of the whole landscape — Colorado alone changed three times in 18 months
ISO/IEC 42001	iso.org	Confirm you're citing the current published edition, not a draft
FDA AI/ML device guidance	fda.gov	FDA guidance documents are dated and versioned — check the date on whatever you're citing

The habit that matters more than any single bookmark: before stating a regulatory fact as settled in a design doc, a customer conversation, or a compliance sign-off, ask "when did I last confirm this against a primary source, and has anything with public attention (a lawsuit ruling, an election, an EU trilogue) moved in the meantime?" Treat regulatory facts with the same skepticism you'd apply to a training-data cutoff date on a model card.

5. Forward links

Idea here	Where it returns
Model cards, risk registers as shared evidence	Module 12 [12-ai-governance]
Eval reports as accuracy/robustness/bias evidence	Module 15 [15-ai-evals]
Audit logs as record-keeping evidence	Module 13 [13-ai-security]
The classifier and mapper tools that operationalize this file	<code>code/eu_ai_act_risk_classifier.py</code> [14-ai-compliance/code/eu_ai_act_risk_classifier.py], <code>code/compliance_documentation_mapper.py</code> [14-ai-compliance/code/compliance_documentation_mapper.py]